

OWASP Mobile Top 10 Research

Introduction

What is the OWASP Mobile Top 10?

The OWASP Mobile Top 10 is a comprehensive list of the most critical security risks found in mobile applications. Maintained by the Open Web Application Security Project (OWASP), this list serves as a security benchmark for developers, security professionals, and organizations to identify, mitigate, and prevent vulnerabilities in mobile apps. It provides essential guidance for writing secure code and ensures compliance with frameworks like the Mobile Application Security Verification Standard (MASVS).



Key Risks and Vulnerabilities (2023)

- **Improper Credential Usage (M1)**
 - Vulnerabilities arise when apps hardcode credentials or fail to handle authentication tokens securely, leading to unauthorized account access.
- **Inadequate Supply Chain Security (M2)**
 - Risks stem from the inclusion of vulnerable third-party libraries or SDKs that compromise the overall security of the mobile application.

What is the impact of these issues?

- **Data Breaches and Privacy Leaks**
 - Exploiting mobile vulnerabilities like Insecure Data Storage (M9) can lead to the theft of sensitive user information or personal identifying data (PII).
- **Regulatory and Compliance Failures**
 - Failure to follow OWASP standards results in non-compliance with global regulations such as GDPR, HIPAA, or PCI DSS, incurring heavy penalties.

Case Study

Insecure Data Storage in a Health Tracking App

A popular health tracking application stores detailed user medical history and biometric data in a local SQLite database on the mobile device to enable offline access for the user.

The Vulnerability (Unencrypted Local Storage)

The application developers fail to implement database encryption, leaving the SQLite file in a world-readable directory. This lack of protection violates Insecure Data Storage (M9) principles by exposing sensitive health data to other processes on the device.

The Attack

An attacker uses a malicious app or gains physical access to a rooted/jailbroken device to browse the file system. They locate the unencrypted database at a path like [/data/data/com.health.app/databases/userinfo.db](#). Using a simple SQLite viewer, they extract all stored medical records.

Result

The attacker successfully extracts highly private medical information. This scenario shows how failing to secure data at rest on mobile devices leads to severe privacy violations and potential identity theft.

Mitigations and Best Practices

- **Adherence to MASVS Levels**

- Implement security controls based on MASVS-L1 for standard apps, MASVS-L2 for high-security apps, and MASVS-R for resilience against reverse engineering.

- **Utilize MASTG for Testing**

- Employ the Mobile Application Security Testing Guide (MASTG) for systematic static and dynamic analysis to identify vulnerabilities early in the SDLC.

- **Secure Coding and Risk Mitigation**

- Reduce vulnerabilities by educating developers on the OWASP Top 10 to improve security awareness and prevent data leaks.

Conclusion

The OWASP Mobile Top 10 remains the industry standard for securing mobile applications against evolving threats. By addressing critical risks such as insecure communication, improper credential usage, and insecure data storage, organizations can protect sensitive user data and ensure regulatory compliance. A layered defense strategy incorporating MASVS and MASTG frameworks is essential for building resilient and trustworthy mobile ecosystems.

References

<https://github.com/OWASP/owasp-masvs>

<https://github.com/OWASP/owasp-mastg>

<https://owasp.org/www-project-mobile-top-10/>

<https://blog.securelayer7.net/a-guide-to-owasp-top-10-mobile-security-risks-2024/>